

CVEs más relevantes de la semana

Del 09/05/2026 al 16/05/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-42601

Descripción: ArchiveBox is an open source self-hosted web archiving system. In versions 0.8.6rc0 and prior, the /add/ endpoint (AddView in core/views.py) accepts a config JSON field that gets merged into the crawl config without validation. This config is exported as environment variables when archive plugins run, allowing injection of arbitrary tool arguments to achieve RCE. At time of publication, there a...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-88

Tecnología: No especificado

Publicado el: 2026-05-09



CVE-2025-14179

Descripción: In PHP versions 8.2.* before 8.2.31, 8.3.* before 8.3.31, 8.4.* before 8.4.21, and 8.5.* before 8.5.6, the PDO Firebird driver improperly handles NUL bytes when preparing SQL queries. During token-by-token query construction, a string token containing a NUL byte is copied via `strncat()`, which stops at the NUL byte, dropping the closing quote and causing subsequent SQL tokens to be interpreted a...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-05-10



CVE-2026-6722

Descripción: In PHP versions 8.2.* before 8.2.31, 8.3.* before 8.3.31, 8.4.* before 8.4.21, and 8.5.* before 8.5.6, the SOAP extension's object deduplication mechanism stores pointers to PHP objects in a global map without incrementing their reference counts. When an apache:Map node contains duplicate keys, processing the second entry overwrites the first in the temporary result map, freeing the original PH...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-05-10



CVE-2026-7261

Descripción: In PHP versions 8.2.* before 8.2.31, 8.3.* before 8.3.31, 8.4.* before 8.4.21, and 8.5.* before 8.5.6, when SoapServer is configured with SOAP_PERSISTENCE_SESSION, the handler object is persisted across requests via session storage. However, in the case SOAP requests results in an error, the persistence is handled incorrectly, resulting in freeing the object while keeping a pointer to it, which...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-05-10



CVE-2026-6104

Descripción: In PHP versions 8.4.* before 8.4.21 and 8.5.* before 8.5.6, when an encoding name containing an embedded NUL byte is passed to `mb_convert_encoding()` or related mbstring functions, the code incorrectly assumes that when `strncasecmp()` returns 0 it means the strings have the same length. This can lead to out-of-bounds read of global memory, potentially causing a crash or information disclosure or ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-05-10



CVE-2021-47923

Descripción: OpenCart 3.0.3.8 contains a session fixation vulnerability that allows attackers to hijack user sessions by injecting arbitrary values into the OCSESSID cookie. Attackers can set malicious OCSESSID cookie values that the server accepts and maintains, enabling session takeover and unauthorized access to user accounts.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-05-10



CVE-2021-47932

Descripción: WordPress TheCartPress 1.5.3.6 contains an unauthenticated privilege escalation vulnerability that allows attackers to create administrator accounts by submitting crafted requests to the AJAX handler. Attackers can send POST requests to the tcp_register_and_login_ajax action with tcp_role set to administrator to gain full administrative access without authentication.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-05-10



CVE-2021-47933

Descripción: WordPress MStore API 2.0.6 contains an arbitrary file upload vulnerability that allows unauthenticated attackers to upload malicious files by sending POST requests to the REST API endpoint. Attackers can upload PHP files with arbitrary names to the config_file endpoint to achieve remote code execution on the server.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-10



CVE-2021-47936

Descripción: OpenCATS 0.9.4 contains a remote code execution vulnerability that allows unauthenticated attackers to execute arbitrary commands by uploading malicious PHP files disguised as resume attachments. Attackers can upload PHP payloads through the careers job application endpoint and execute system commands via POST requests to the uploaded file in the upload directory.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-10



CVE-2021-47940

Descripción: WordPress Plugin Download From Files version 1.48 and earlier contains an arbitrary file upload vulnerability that allows unauthenticated attackers to upload malicious files by exploiting the AJAX fileupload action. Attackers can send POST requests to the admin-ajax.php endpoint with the download_from_files_617_fileupload action, manipulating the allowExt parameter to bypass file type restricti...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-10



CVE-2026-8263

Descripción: A security flaw has been discovered in Tenda AC6 15.03.06.49_multi_TDE01. Affected is the function fromSetWirelessRepeat of the file /goform/WifiExtraSet of the component httpd. Performing a manipulation of the argument mac/ssid results in os command injection. It is possible to initiate the attack remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 4.7 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-05-11



CVE-2026-35157

Descripción: Dell ECS versions 3.8.1.0 through 3.8.1.7 and Dell ObjectScale versions prior to 4.3.0.0, contains an improper neutralization of formula elements in a CSV File vulnerability in the UI. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.

CVSS: 5.8 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:L/I:L/A:L

Tipo: CWE-1236

Tecnología: No especificado

Publicado el: 2026-05-11



CVE-2026-42608

Descripción: Grav is a file-based Web platform. Prior to 2.0.0-beta.2, there is a Path Traversal vulnerability within the FormFlash core component. By manipulating the session_id (passed as __form-flash-id in POST requests), an unauthenticated attacker can traverse the filesystem to create arbitrary directories and write an index.yaml file containing attacker-controlled data. This vulnerability can lead to ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-05-11



CVE-2026-44643

Descripción: Angular Expressions provides expressions for the AngularJS web framework as a standalone module. Prior to 1.5.2, an attacker can write a malicious expression using filters that escapes the sandbox to execute arbitrary code on the system. This vulnerability is fixed in 1.5.2.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-95

Tecnología: No especificado

Publicado el: 2026-05-11



CVE-2026-42858

Descripción: Open edX Platform enables the authoring and delivery of online learning at any scale. The `sync_provider_data` endpoint in `SAMLProviderDataSet` allows authenticated Enterprise Admin users to supply an arbitrary URL via the `metadata_url` POST parameter. This URL is passed directly to `requests.get()` in `fetch_metadata_xml()` without any URL validation, IP filtering, or scheme enforcement. An attack...

CVSS: 8.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-05-11



CVE-2026-43639

Descripción: Bitwarden Server prior to v2026.4.0 contains a missing authorization vulnerability that allows a provider service user to add an arbitrary organization to their provider via `POST /providers/{providerId}/clients/existing`, resulting in takeover of the target organization; self-hosted installations are unaffected as this endpoint is restricted to Cloud via `SelfHosted(NotSelfHostedOnly = true)`.

CVSS: 8.0 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-05-11



CVE-2026-7210

Descripción: `xml.parsers.expat` and `xml.etree.ElementTree` use insufficient entropy for Expat hash-flooding protection, which allows a crafted XML document to trigger hash flooding.\r\n\r\nFully mitigating this vulnerability requires both updating libexpat to 2.8.0 or later and applying this patch.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-331

Tecnología: No especificado

Publicado el: 2026-05-11



CVE-2026-8305

Descripción: A vulnerability was detected in OpenClaw up to 2026.1.24. The impacted element is the function `handleBlueBubblesWebhookRequest` of the file `extensions/bluebubbles/src/monitor.ts` of the component `bluebubbles Webhook`. Performing a manipulation results in improper authentication. It is possible to initiate the attack remotely. The exploit is now public and may be used. Upgrading to version 2026.2.1...

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-05-11



CVE-2026-43914

Descripción: Vaultwarden is a Bitwarden-compatible server written in Rust. Prior to 1.35.4, there is a security vulnerability in Vaultwarden that allows bypassing the login brute-force protection if email 2fa is enabled. If email 2fa is enabled, the unprotected 2fa-function send_email_login (email.rs, api endpoint /api/two-factor/send-email-login) also acts as an oracle determining whether a username-passwo...

CVSS: 7.3 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-307

Tecnología: No especificado

Publicado el: 2026-05-11



CVE-2026-34260

Descripción: SAP S/4HANA (SAP Enterprise Search for ABAP) contains a SQL injection vulnerability that allows an authenticated attacker to inject malicious SQL statements through user-controlled input. The application directly concatenates this malicious user input into SQL queries, which are then passed to the underlying database without proper validation or sanitization. Upon successful exploitation, an at...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2025-40949

Descripción: A vulnerability has been identified in RUGGEDCOM ROX MX5000 (All versions < V2.17.1), RUGGEDCOM ROX MX5000RE (All versions < V2.17.1), RUGGEDCOM ROX RX1400 (All versions < V2.17.1), RUGGEDCOM ROX RX1500 (All versions < V2.17.1), RUGGEDCOM ROX RX1501 (All versions < V2.17.1), RUGGEDCOM ROX RX1510 (All versions < V2.17.1), RUGGEDCOM ROX RX1511 (All versions < V2.17.1), RUGGEDCOM ROX RX1512 (All v...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2025-6577

Descripción: Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Akilli Commerce Software Technologies Ltd. Co. E-Commerce Website allows SQL Injection.

This issue affects E-Commerce Website: before 4.5.001.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-22924

Descripción: A vulnerability has been identified in SIMATIC CN 4100 (All versions < V5.0). The affected application does not properly restrict unauthenticated connections and is susceptible to resource exhaustion conditions. This could allow an attacker to disrupt normal operations or perform unauthorized actions, potentially impacting system availability and integrity.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-25786

Descripción: Affected devices do not properly validate and sanitize PLC/station name rendered on the "communication" parameters page of the web interface. This could allow an authenticated attacker who is authorized to download a TIA project into the product, to inject malicious scripts into the page. If a benign user with appropriate rights accesses the "communication" parameters page, the malicious code...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-25787

Descripción: Affected devices do not properly validate and sanitize Technology Object (TO) name rendered on the "Motion Control Diagnostics" page of the web interface. This could allow an authenticated attacker who is authorized to download a TIA project into the product, to inject malicious scripts into the page. If a benign user with appropriate rights accesses the "Motion Control Diagnostics" parameters...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-41551

Descripción: A vulnerability has been identified in ROS# (All versions < V2.2.2). Affected versions contain a path traversal vulnerability because user input is not properly sanitized. This could allow a remote attacker to access arbitrary files on the device.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-23

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-30805

Descripción: Insecure Default Initialization of Resource vulnerability allows Authentication Bypass via API access. This issue affects Pandora FMS: from 777 through 800

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-1188

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-34187

Descripción: Improper Neutralization of Special Elements used in an SQL Command vulnerability allows SQL Injection via graph container parameter. This issue affects Pandora FMS: from 777 through 800

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-33117

Descripción: Improper authentication in Azure SDK allows an unauthorized attacker to bypass a security feature over a network.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-33821

Descripción: Improper privilege management in Microsoft Dynamics 365 Customer Insights allows an authorized attacker to elevate privileges over a network.

CVSS: 7.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:N/I:H/A:N

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-41089

Descripción: Stack-based buffer overflow in Windows Netlogon allows an unauthorized attacker to execute code over a network.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-41096

Descripción: Heap-based buffer overflow in Microsoft Windows DNS allows an unauthorized attacker to execute code over a network.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-41103

Descripción: Incorrect implementation of authentication algorithm in Microsoft SSO Plugin for Jira & Confluence allows an unauthorized attacker to elevate privileges over a network.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-303

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-34659

Descripción: Adobe Connect versions 2025.9.15, 2025.8.157 and earlier are affected by a Deserialization of Untrusted Data vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue requires user interaction in that a victim must visit a maliciously crafted URL or interact w...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-34660

Descripción: Adobe Connect versions 2025.9.15, 2025.8.157 and earlier are affected by an Incorrect Authorization vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to inject malicious scripts into a web page, potentially gaining elevated access or control over the victim's account or session. Exploitation of this issue...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2026-44015

Descripción: Nginx UI is a web user interface for the Nginx web server. In 2.3.4 and earlier, an authenticated user can perform Server-Side Request Forgery (SSRF) by creating a cluster node pointing to an arbitrary internal URL and then sending API requests with the X-Node-ID header. The Proxy middleware forwards these requests to the attacker-specified internal address, bypassing network segmentation and e...

CVSS: 8.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-05-12



CVE-2020-37168

Descripción: Ecommerce Systempay 1.0 contains a weak cryptographic implementation vulnerability that allows attackers to brute force the 16-character production secret key used for payment signature generation. Attackers can extract payment form data and signatures from POST requests to the payment endpoint, then use SHA1 hash comparison to iteratively test key candidates until discovering the correct produ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-328

Tecnología: No especificado

Publicado el: 2026-05-13



CVE-2026-41225

Descripción: A vulnerability exists in iControl REST where a highly privileged, authenticated attacker with at least the Manager role can create configuration objects that allow running arbitrary commands.

Note: Software versions which have reached End of Technical Support (EoTS) are not evaluated.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-648

Tecnología: No especificado

Publicado el: 2026-05-13



CVE-2026-42031

Descripción: CKAN is an open-source DMS (data management system) for powering data hubs and data portals. Prior to 2.10.10 and 2.11.5, a vulnerability in `datastore_search_sql` allowed attackers to inject SQL in order to gain access to private resources and PostgreSQL system information. This vulnerability is fixed in 2.10.10 and 2.11.5.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-05-13



CVE-2026-42032

Descripción: CKAN is an open-source DMS (data management system) for powering data hubs and data portals. Prior to 2.10.10 and 2.11.5, a vulnerability in `datastore_search_sql` allowed attackers to bypass authorization in order to gain access to private resources and PostgreSQL system information. This vulnerability is fixed in 2.10.10 and 2.11.5.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-05-13



CVE-2026-8181

Descripción: The Burst Statistics – Privacy-Friendly WordPress Analytics (Google Analytics Alternative) plugin for WordPress is vulnerable to Authentication Bypass in versions 3.4.0 to 3.4.1.1. This is due to incorrect return-value handling in the ``is_mainwp_authenticated()`` function when validating application passwords from the Authorization header. This makes it possible for unauthenticated attackers, wi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-05-14



CVE-2026-6271

Descripción: The Career Section plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 1.7 via the CV upload handler. This is due to missing file type validation. This makes it possible for unauthenticated attackers to upload files that may be executable, which makes remote code execution possible.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-05-14



CVE-2026-6510

Descripción: The InfusedWoo Pro plugin for WordPress is vulnerable to privilege escalation via missing authorization in all versions up to, and including, 5.1.2. This is due to missing nonce verification and capability checks in the `iwar_save_recipe()` AJAX handler. This makes it possible for unauthenticated attackers to create a malicious automation recipe that pairs an HTTP post trigger with an auto-login ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-05-14



CVE-2026-6512

Descripción: The InfusedWoo Pro plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 5.1.2. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to permanently delete arbitrary posts, pages, products, or orders, mass-delete all comments on any post, and change any post...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-05-14



CVE-2025-11024

Descripción: Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Akilli Commerce Software Technologies Ltd. Co. E-Commerce Website allows Blind SQL Injection.

This issue affects E-Commerce Website: before 4.5.001.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-05-14



CVE-2026-2347

Descripción: Authorization bypass through User-Controlled key vulnerability in Akilli Commerce Software Technologies Ltd. Co. E-Commerce Website allows Session Hijacking.

This issue affects E-Commerce Website: before 4.5.001.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-05-14



CVE-2026-5229

Descripción: The Form Notify plugin for WordPress is vulnerable to Authentication Bypass in versions up to and including 1.1.10. This is due to the plugin trusting user-controlled cookie data to determine which WordPress account to authenticate after a LINE OAuth login. When LINE doesn't provide an email address (which is common), the plugin falls back to reading the 'form_notify_line_email' cookie value wi...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-05-15



CVE-2021-47965

Descripción: WordPress Plugin WP Super Edit 2.5.4 and earlier contains an unrestricted file upload vulnerability in the FCKeditor component that allows attackers to upload dangerous file types without validation. Attackers can upload arbitrary files through the filemanager upload endpoint to achieve remote code execution and complete system compromise.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-05-15



CVE-2026-46364

Descripción: phpMyFAQ before 4.1.2 contains an unauthenticated SQL injection vulnerability in BuiltinCaptcha::garbageCollector() and BuiltinCaptcha::saveCaptcha() methods that interpolate unsanitized User-Agent headers into DELETE and INSERT queries. Unauthenticated attackers can exploit the public GET /api/captcha endpoint by crafting malicious User-Agent headers to perform time-based blind SQL injection, ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-05-15



Resumen del Reporte

CVEs analizados: 49

Promedio CVSS: 9.18

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

